ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

AutomationDirect Productivity2000 (P2-550) Micro-Modular PLC · Component type: **Embedded Device (EDR) - programmable logic controller (PLC)** · Target SL = SL 3

Where to work	Configure with the free **Productivity Suite** software (Windows) over the **micro-B USB** port or **Ethernet**: tags/logic, the **project password / transfer protection**, comms setup (Modbus / EtherNet/IP / MQTT(S)), and firmware. The CPU **OLED display + keypad** give local status/config/alarms; a **microSD** card does data logging. No user accounts/RBAC on the PLC - the project password is the native access control, and firmware **patching** is the primary control against the known RCE.
Ports / paths	**micro-B USB 2.0** (programming/monitoring/firmware); **general-purpose Ethernet 10/100**: Modbus TCP **502** (client/server), EtherNet/IP **TCP 44818 / UDP 2222**, **MQTT 1883 / MQTTS 8883**; **remote-I/O Ethernet 10/100** (P2 remote slaves); **2 serial ports** (RS-232 + RS-485) Modbus RTU/ASCII. microSD (data log); OLED + keypad. No TLS on Modbus/EtherNet-IP (unauthenticated); **MQTTS** is the one encrypted option.
Notes / CVEs	AutomationDirect **Productivity2000 (P2-550)**. **CRITICAL - patch firmware**: the Productivity PLC line has had an **unauthenticated RCE** (CISA **ICSA-24-144-01**, up to CVSS 10.0) and the Productivity Suite has multiple CVEs (ICSA-25-296-01) - update PLC firmware to the latest and Productivity Suite to **4.7.0.47+**. No user accounts/RBAC; unauthenticated Modbus/EtherNet-IP - native control = project password + disable-unused-protocols + physical; compensate with segmentation + monitoring + patching. Confirm CPU firmware.
How to read	Default read-only (Productivity Suite read-only project review; read-only Modbus/EtherNet-IP reads; OLED/data-log review). Each row = native step-by-step + command-level external-tool validation + pass. Write/exploit tools = isolated bench + written authorization (a mis-set PLC can start a process). Given the CVSS-10 RCE, several rows hinge on PATCHING + isolation.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 1.1	Human user identification & auth	The PLC has **no user accounts**. Access control is the **project password / transfer protection** in Productivity Suite (gates opening + transferring the project) - set it. But the programming/runtime path had an **unauthenticated RCE (ICSA-24-144-01)** and Modbus/EtherNet-IP are unauthenticated - so **patch firmware** and compensate with segmentation + physical control. **Test:** in Productivity Suite, open/transfer the project without the password -> denied; confirm the CPU firmware is patched (not vulnerable to the ICSA-24-144-01 RCE). **Ext. tools:** Productivity Suite (project-password review); confirm firmware version vs the CISA-fixed release; `nmap -p 502,44818,1883,8883 .`	Project password set; firmware patched against the RCE; unauthenticated protocols compensated by segmentation.	EDR - patch-critical; compensating.
SR/CR 1.2	Device & software-process I&A;	Modbus/EtherNet-IP are **unauthenticated**; the PLC is identified by its **IP** (general + remote-I/O ports) and Modbus station address. Bind identity by a single known master + segmentation; where MQTT is used, prefer **MQTTS** so the broker connection authenticates. **Test:** from an unauthorized host, poll Modbus/EtherNet-IP -> blocked by segmentation. **Ext. tools:** `modpoll -m tcp -a` (read-only); `nmap --script enip-info -p 44818` ; confirm MQTTS (8883) not plain 1883.	PLC identified by IP/address; single authorized master; MQTTS where used; unauthenticated protocols compensated.	No native auth - Compensating.
SR/CR 1.3	Account management	No PLC accounts; manage the **project password** as a controlled secret, the Productivity Suite host access, and any **MQTT broker** credentials (change defaults). Keep custody of the project (.adpro). **Ext. tools:** Project-password custody; host review; MQTT broker credential review; project custody.	Project password + host + broker credentials controlled; defaults changed.	
SR/CR 1.4	Identifier management	Confirm a unique **IP** on each Ethernet port (general vs remote-I/O), a unique Modbus station address, and a unique CPU identity (P2-550 + serial); no reuse. **Ext. tools:** Productivity Suite (IP/address); `modpoll` scan for collisions; asset register.	Unique IPs/address + CPU identity; no reuse.	
SR/CR 1.5	Authenticator management	Set a **strong project password** and note the Productivity Suite **weak-password-recovery CVE (CVE-2025-61977)** - patch Suite to 4.7.0.47+ so the password cannot be bypassed via a recovery question; set strong MQTTS credentials; host/AD policy. **Ext. tools:** Productivity Suite (password + patched version); MQTTS credential review; host/AD policy.	Strong project password (Suite patched so recovery cannot bypass it); MQTTS creds; managed lifecycle.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR 1.6	Wireless access management	**N/A.** Wired PLC with no native wireless interface. **Ext. tools:** Confirm no wireless.	N/A - justification recorded (wired device).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	Public key infrastructure (PKI) certificates	**Limited at device.** Modbus/EtherNet-IP have no TLS/PKI; the one crypto path is **MQTTS** (TLS to the broker) - confirm CA-signed broker certs/strong keys where MQTT is used. Otherwise record N/A + segmentation. **Ext. tools:** MQTTS TLS check (openssl s_client to the broker); confirm no other device crypto; Wireshark (Modbus/EtherNet-IP cleartext).	MQTTS TLS where used (CA-signed); no other device PKI (compensated by segmentation).	N/A/Partial.
SR/CR 1.9	Strength of public key-based authentication	Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of public key-based authentication verified individually.	
SR/CR 1.10	Authenticator feedback	Confirm the project-password entry is masked in Productivity Suite (no cleartext echo). **Ext. tools:** Visual verification (Productivity Suite).	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	The PLC has **no lockout** on the protocols/programming; compensate with the project password (patched Suite), segmentation, physical control, and monitoring of anomalous writes/connection attempts. **Ext. tools:** OT IDS on the cell; SIEM connection-attempt review.	No native lockout; project password + segmentation + monitoring compensate.	Legacy limitation.
SR/CR 1.12	System use notification	No banner on the protocols; use the **OLED custom message** and a placard on the cabinet; enforce the notice on the Productivity Suite host (GPO). **Ext. tools:** OLED message; physical placard; host `gpresult /h gp.html`.	Use notice via OLED/placard/host (compensating at protocol layer).	Compensating.
SR 1.13	Access via untrusted networks	Segment the PLC; firewall the **general-purpose Ethernet** (502/44818/1883/8883) and the programming path; keep the **remote-I/O Ethernet** on its own isolated segment; no protocols/programming from untrusted networks; remote via VPN/jump host. **The CVSS-10 RCE makes strong isolation essential.** **Test:** from an untrusted VLAN, reach 502/44818/programming -> must fail. **Ext. tools:** `nmap -Pn -p 502,44818,2222,1883,8883` from the untrusted side (expect filtered); firewall review.	PLC unreachable from untrusted networks; remote-I/O isolated; remote via VPN.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 2.1	Authorization enforcement	No role model. Authorization is the **project password** (gates programming/transfer) plus restricting which **Modbus registers / tags** are writable at the master, and RUN/STOP control via Productivity Suite / the OLED keypad. Confirm a read-only path cannot write. **Test:** attempt a program transfer without the password -> denied; attempt a write to a protected tag from an unauthorized master -> blocked. **Ext. tools:** Productivity Suite (password + tag write scope); `modpoll` write test (authorized/isolated).	Programming gated by project password; write scope restricted at the master.	No device roles - Compensating.
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 2.3	Use control for portable/mobile devices	Control the Productivity Suite laptop, the **USB** port, and the **microSD** card; only authorized projects/firmware loaded; restrict who runs Productivity Suite. **Ext. tools:** Host removable-media GPO; physical control of USB/microSD; project/firmware provenance.	Engineering media + USB/microSD controlled; only authorized artifacts loaded.	
SR/EDR 2.4	Mobile code	**N/A.** Fixed-function firmware executing the compiled tag-based project - no general-purpose or downloadable code beyond firmware. **Ext. tools:** Confirm fixed-function device (no code path beyond firmware + project).	N/A - no mobile-code capability (fixed firmware + project).	EDR-specific / N/A.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 2.5	Session lock	**N/A at device** (no interactive login). Enforce workstation lock on the Productivity Suite EWS. **Ext. tools:** EWS inactivity-lock GPO.	EWS locks on inactivity (N/A at device).	Compensating.
SR/CR 2.6	Remote session termination	Confirm the CPU bounds concurrent Modbus/EtherNet-IP connections and a Productivity Suite session can be closed; no conflicting concurrent programming. **Ext. tools:** Productivity Suite (connections); `nmap --script enip-info`; Wireshark (teardown).	Connections bounded; programming session controlled.	
SR/CR 2.7	Concurrent session control	Confirm concurrent sessions are bounded/limited and monitored. **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Concurrent session control verified individually.	
SR/CR 2.8	Auditable events	The PLC has **limited native logging** (system alarms on the OLED; data log to microSD) and no security syslog. Capture change attribution via **Productivity Suite project change tracking**, the controlling SCADA/master, and a Modbus/EtherNet-IP-aware OT IDS; forward to the SIEM. **Ext. tools:** Productivity Suite (project compare/change); SCADA change log; OT IDS + SIEM.	Changes attributable via project compare + SCADA; PLC events captured by IDS.	No native syslog - Compensating.
SR/CR 2.9	Audit storage capacity	Because security logging is off-device, confirm the SCADA/SIEM are sized/retained and alert on collection or PLC comms-loss failure. **Ext. tools:** SCADA/SIEM retention + comms-loss alarm review.	Off-device logs sized/retained; audit-failure/comms-loss alerting defined.	Compensating.
SR/CR 2.10	Response to audit processing failures	Confirm a defined response to audit-processing/forwarding failures (alerting; no silent loss). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.9** above (shared steps); confirm this requirement individually and adjudicate it separately.	Response to audit processing failures verified individually.	
SR/CR 2.11	Timestamps	Confirm the CPU **RTC** is synced (SNTP/NTP) so data-log and event timestamps are accurate and correlate with the SCADA/SIEM. **Ext. tools:** Productivity Suite (time/SNTP config); `nmap -sU -p 123 .`	Accurate synchronized time; events correlate.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	
EDR 2.13	Physical diagnostic & test interfaces	Control physical interfaces: locked cabinet; the **USB**, the two **serial** ports, the two **Ethernet** ports, the **microSD** slot, and the **OLED keypad** (local config/RUN control); shut/disable unused I/O. **Ext. tools:** Physical inspection (cabinet, USB/serial/Ethernet/microSD, keypad access).	Physical/diagnostic interfaces controlled; cabinet locked; keypad access limited.	EDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 3.1	Communication integrity	Modbus/EtherNet-IP + the programming path are **unauthenticated cleartext** (no TLS) - integrity/confidentiality come from **containment** (segmented cell) plus **MQTTS** for the broker link where MQTT is used. No cleartext control crosses a zone boundary uncontrolled. **Test:** confirm control protocols stay in-zone; MQTT uses MQTTS (8883) not 1883. **Ext. tools:** Wireshark (`modbus || enip` cleartext in-zone; MQTTS TLS); `nmap -p 502,44818,1883,8883 .`	Control comms contained/segmented; MQTTS used; no uncontrolled cleartext.	No TLS on control - Compensating.
SR/EDR 3.2	Protection from malicious code (component)	Confirm only AutomationDirect firmware runs. **Patch the unauthenticated RCE** (ICSA-24-144-01) and load firmware only from AutomationDirect; verify provenance; there is no documented signed-boot on this platform - provenance + patching are the controls. **Ext. tools:** Productivity Suite (firmware version vs CISA-fixed); AutomationDirect provenance; CISA advisory review.	Only vendor firmware runs; RCE-patched; provenance verified.	EDR-specific / patch-critical.
SR/CR 3.3	Security functionality verification	After any change re-verify: project password, disabled unused protocols, MQTTS, firmware (patched), and segmentation, against the baseline; compare the Productivity Suite project. **Ext. tools:** Productivity Suite (project + settings vs baseline); `nmap -p 502,44818,1883,8883 .`	Security settings match the baseline after change.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 3.4	Software & information integrity	Protect the **.adpro project** (host ACLs, version control); the project password + transfer protection prevent unauthorized change; note the Suite **project-decryption CVE (CVE-2025-61977)** - patch Suite; hash the project; detect drift by compare. **Ext. tools:** Host ACL on the project; `certutil -hashfile .adpro SHA256`; Productivity Suite compare for drift.	Project integrity protected; unauthorized change prevented/detected; Suite patched.	
SR/CR 3.5	Input validation	**Patch the RCE** and confirm the CPU tolerates malformed **Modbus / EtherNet-IP / MQTT** frames without faulting or unexpected run. **ISOLATED bench only:** fuzz on a bench PLC (outputs uncoupled) and watch the fault/OLED state. **Ext. tools:** Fieldbus fuzzer (`boofuzz`) on a bench PLC; watch OLED/system alarms + outputs; confirm firmware patched.	RCE patched; no fault/unexpected run on malformed input.	Do NOT fuzz an in-service PLC.
SR/CR 3.6	Deterministic output	**Safety-relevant row.** Verify configured output behavior on CPU stop / comm loss - I/O **fault/hold-last** and the program fail-safe logic drive outputs to a defined safe state; confirm the comm-loss handling for Modbus/EtherNet-IP data used in control. **Test:** ISOLATED: force CPU STOP / comm loss -> outputs go to the configured safe state. **Ext. tools:** Productivity Suite (I/O fault/hold config + fault logic); bench fault injection.	Outputs go to a defined/fail-safe state on fault or comm loss.	Safety-relevant.
SR/CR 3.7	Error handling	Confirm graceful fault handling: system alarms on the OLED / data log record the cause; any auto-restart is reviewed (no unsafe auto-restart); no info leak. **Ext. tools:** Productivity Suite / OLED (system alarms + restart config review).	Graceful fault handling; no unsafe auto-restart or info leak.	
SR/CR 3.8	Session integrity	**N/A / limited.** No authenticated/encrypted control session (MQTTS excepted); integrity by containment. Record N/A + compensating segmentation. **Ext. tools:** Wireshark (confirm containment; MQTTS session where used).	N/A/limited at device; MQTTS where used; compensating segmentation.	N/A/Partial.
SR/CR 3.9	Protection of audit information	Since audit is largely off-device, protect the SCADA/IDS/SIEM store + the microSD data log; restrict who can read/clear. **Ext. tools:** SCADA/SIEM access review; microSD physical control.	Off-device + data-log audit records protected from unauthorized access.	
EDR 3.10	Support for updates	Update firmware via Productivity Suite (USB/Ethernet) with firmware from AutomationDirect; verify version/provenance; **apply the ICSA-24-144-01 fix**; maintenance window with a project/firmware rollback plan. **Ext. tools:** Productivity Suite (update flow + provenance); AutomationDirect firmware; rollback plan.	Controlled updates from a verified source, RCE-patched, with rollback.	EDR-specific.
EDR 3.11	Physical tamper resistance/detection	Keep the PLC in a locked/sealed cabinet; control the USB/serial/Ethernet/microSD and the OLED keypad; config drift is visible via Productivity Suite compare. **Ext. tools:** Physical inspection (cabinet/seal, ports, microSD, keypad); Productivity Suite compare.	Cabinet secured; interfaces controlled; drift detectable.	EDR-specific.
EDR 3.12	Provisioning product-supplier roots of trust	**Partial/N-A at device.** No documented signed-firmware supplier root of trust on this platform. Record the gap; compensate with firmware provenance (3.10), the RCE patch, physical control, and segmentation. **Ext. tools:** Confirm firmware provenance/signing level with AutomationDirect.	Supplier trust via provenance + patching; attestation gap recorded.	EDR-specific/Partial.
EDR 3.13	Provisioning asset-owner roots of trust	**N/A at device.** No asset-owner certificate provisioning (except MQTTS broker trust). Record the gap; asset-owner trust at the network + physical + project-password layer. **Ext. tools:** Confirm no device cert provisioning (MQTTS excepted); segmentation review.	No asset-owner RoT at device; network/project controls compensate.	EDR-specific / N/A.
EDR 3.14	Integrity of the boot process	**N/A at device.** No published secure-boot attestation. Record the gap; mitigate via firmware provenance (3.10), the RCE patch, physical control, and monitoring. **Ext. tools:** Confirm boot-integrity level with AutomationDirect; firmware version review.	Boot-integrity gap recorded; compensating controls in place.	EDR-specific / N/A.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose, clear the project/memory (Productivity Suite clear + factory reset), erase/destroy the **microSD**, and remove the project password/backups so program and configuration are not recoverable. **Ext. tools:** Productivity Suite (clear + factory reset); microSD sanitize/destroy.	Program/config/microSD purged on decommission or reuse.	
SR/CR 4.3	Use of cryptography	**Limited.** The one comms crypto is **MQTTS** (broker TLS); the project is encrypted (patch the weak-recovery CVE); no other comms crypto. Rely on segmentation + host disk encryption for the project. **Ext. tools:** MQTTS TLS check; confirm project encryption + patched Suite; segmentation review.	MQTTS + project encryption (patched); other comms compensated by segmentation.	N/A/Partial.

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 5.1	Network segmentation	Confirm the PLC sits in a segmented cell; the **general-purpose Ethernet is the exposure point** (Modbus/EtherNet-IP/MQTT/programming) - firewall it; keep the **remote-I/O Ethernet on its own isolated segment**; only required flows cross; no flat IT convergence. The CVSS-10 RCE demands strong isolation. **Ext. tools:** `nmap -p 502,44818,2222,1883,8883` per zone; firewall + remote-I/O isolation review.	PLC in a segmented cell; remote-I/O isolated; only required flows cross.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Single-purpose controller with no person-to-person messaging. **Ext. tools:** Confirm no such services.	N/A - justification recorded.	N/A
SR 5.4	Application partitioning	Confirm the **remote-I/O Ethernet** is partitioned from the general/supervisory Ethernet, and the programming path from the operational protocols. **Ext. tools:** Segmentation review (remote-I/O vs general vs programming).	Remote-I/O and programming partitioned from operational protocols.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 6.1	Audit log accessibility	No native syslog - monitor off-device: the SCADA/master + a Modbus/EtherNet-IP-aware **OT IDS** on the cell, plus the **data log (microSD)** and OLED alarms; forward to the SIEM. Watch for RCE-exploitation attempts. **Ext. tools:** Passive OT IDS (Modbus/EtherNet-IP) on a SPAN; SIEM; Productivity Suite data-log/alarm export.	PLC events monitored off-device in near-real-time; RCE-exploitation watched.	No native syslog - Compensating.
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 7.1	Denial-of-service protection	Confirm resilience: the CPU is sensitive to protocol floods and to the RCE - **patch**, firewall/rate-limit the general-purpose Ethernet, and confirm the **comm-loss fault action** drives outputs to a safe state (no runaway). **Ext. tools:** ISOLATED bench: `hping3 --flood -p 502` / protocol storm; confirm safe comm-fail; confirm firmware patched.	Firmware patched; comm loss drives a safe state; flood rate-limited/segmented.	Patch-critical / Safety-relevant.
SR/CR 7.2	Resource management	Confirm bounded resources: connection limits, scan/comms load, so a single service cannot starve control; monitor via the OLED / Productivity Suite. **Ext. tools:** Productivity Suite (connection/scan load); bench load test.	Resources bounded; no comms-induced loss of control.	
SR/CR 7.3	Control system backup	Confirm the **.adpro project** + firmware record are backed up (versioned, offline) and a restore is tested on a spare CPU; the microSD can hold a copy. **Ext. tools:** Backup repository; `certutil -hashfile .adpro SHA256`; restore test (spare CPU).	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR/CR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Harden: set the project password (Suite patched), **disable unused protocols/ports** (Modbus/EtherNet-IP/MQTT if unused), use **MQTTS not plain MQTT**, set non-default IPs, restrict writable tags, and **patch firmware** (the RCE). **Ext. tools:** Productivity Suite (protocols/password/IP); `nmap -p 502,44818,1883,8883` (only required reachable).	Least functionality; unused protocols off; MQTTS; project password; firmware patched.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Inventory the CPU (P2-550 + firmware), modules, and comms config, so vulnerabilities track against AutomationDirect / CISA advisories (ICSA-24-144-01 PLC RCE; ICSA-25-296-01 Suite). **Ext. tools:** Productivity Suite / OLED (model/firmware); asset register; CISA advisory check.	Accurate CPU/firmware inventory maintained; advisories tracked.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
Productivity Suite	Native config, project-password & firmware (most FRs)	Review tags/logic, the project password/transfer protection, comms (Modbus/EtherNet-IP/MQTTS), firmware, and data log; back up the .adpro; compare for drift. Patch Suite to 4.7.0.47+.	Read/authorized project copy.
CPU OLED display + keypad	Local status/config/RUN review (2.13, 3.7, 6.x)	Review system alarms, IP/config, and local RUN control at the CPU; limit physical keypad access.	Physical; authorized.
modpoll / mbpoll	Modbus read-back & write-scope (1.2, 2.1, 3.3)	`modpoll -m tcp -a` (or RTU on serial); read status; confirm writable tags/registers (authorized/isolated).	Read-only on production; writes isolated.
nmap	Port/service exposure & segmentation (1.13, 3.1, 5.x, 7.x)	`nmap -p 502,44818,2222,1883,8883` ; `nmap --script enip-info -p 44818` ; scan per zone; confirm remote-I/O isolated.	Read-only; authorized.
MQTT client / openssl	MQTTS verification (1.8, 3.1, 4.3)	Confirm MQTT uses MQTTS (8883, TLS) with CA-signed broker certs, not plain 1883; openssl s_client to the broker.	Read-only; authorized.
Wireshark / tcpdump	Comms integrity & containment (1.2, 3.1)	Filter `modbus || enip || mqtt`; confirm cleartext control stays in-zone and MQTTS is encrypted.	Passive; SPAN/tap only.

Tool / method	Verifies	How to use — steps / example	Constraints
Fieldbus fuzzer / hping3 (isolated)	Input validation & DoS (3.5, 7.1)	`boofuzz` Modbus/EtherNet-IP to a BENCH PLC; `hping3 --flood -p 502` storm; watch OLED/outputs; confirm firmware patched.	ISOLATED bench; written authorization.
Passive OT IDS + AutomationDirect / CISA advisories	Monitoring & vuln tracking (2.8, 6.x, 7.8)	Modbus/EtherNet-IP-aware IDS on the cell for events/anomalous writes/RCE attempts; track ICSA-24-144-01 (PLC RCE) + ICSA-25-296-01 (Suite) + required firmware.	Passive; coordinate with SOC.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.